

## Threat Hunt Lab 2: Sudden Network Slowdowns

**Create a VM and onboard it to MDE if you haven't already** — Do not use labuser/Cyberlab123! for credentials (or any other easy password). Your VM will most certainly get breached by a bad actor if it's on long enough. This has already happened once.

Create a (Windows) VM if you don't already have one

Log into it and disable the Windows Firewall (start → run → wf.msc → turn firewall off for all profiles), this is just to let the VM be discovered by bad actors on the Internet more easily

Ensure the Network Security Group is WIDE OPEN, allowing all traffic if you want to generate failed login attempt logs.

Onboard it to MDE if it's not already: [Onboarding a VM to MDE, Isolation, and Investigation](#)

Ensure it's appearing as onboarded in the MDE Portal: <https://security.microsoft.com/machines>

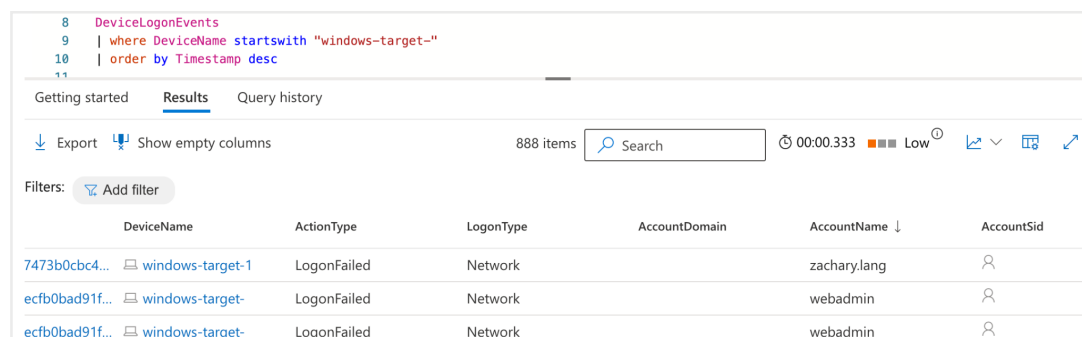
Ensure the logs are showing up in one of the tables. For example, go to Hunting → Advanced Hunting and search for your device in one of the tables. Example query:

### DeviceLogonEvents

| where DeviceName startswith "mydevice-"

| order by Timestamp desc

Example:



The screenshot shows the Advanced Hunting interface with a query executed. The query is: `DeviceLogonEvents | where DeviceName startswith "windows-target-" | order by Timestamp desc`. The results table shows three failed logon attempts for the device "windows-target-1".

| DeviceName     | ActionType  | LogonType | AccountDomain | AccountName ↓ | AccountSid |
|----------------|-------------|-----------|---------------|---------------|------------|
| 7473b0cbc4...  | LogonFailed | Network   |               | zachary.lang  |            |
| ecfb0bad91f... | LogonFailed | Network   |               | webadmin      |            |
| ecfb0bad91f... | LogonFailed | Network   |               | webadmin      |            |

Note: "**windows-target-1**" might be called "**windows-target-**" when you query

for it. MDE will sometimes cut the name off if it's too long.

## Run this PowerShell command on your VM after onboarding it to MDE

```
Invoke-WebRequest -Uri 'https://raw.githubusercontent.com/joshmadakor1/lognpacific-public/refs/heads/main/cyber-range/entropy-gorilla/portscan.ps1' -OutFile 'C:\programdata\portscan.ps1';cmd /c powershell.exe -ExecutionPolicy Bypass -File C:\programdata\portscan.ps1
```

### 1. Preparation

- **Goal:** Set up the hunt by defining what you're looking for.
  - The server team has noticed a significant network performance degradation on some of their older devices attached to the network in the 10.0.0.0/16 network. After ruling out external DDoS attacks, the security team suspects something might be going on internally.
- **Activity:** Develop a hypothesis based on threat intelligence and security gaps (e.g., "Could there be lateral movement in the network?").
  - All traffic originating from within the local network is by default allowed by all hosts. There is also unrestricted use of PowerShell and other applications in the environment. It's possible someone is either downloading large files or doing some kind of port scanning against hosts in the local network.

### 2. Data Collection

- **Goal:** Gather relevant data from logs, network traffic, and endpoints.
  - Consider inspecting the logs for excessive successful/failed connections from any devices. If discovered, pivot and inspect those devices for any suspicious file or process events.
- **Activity:** Ensure data is available from all key sources for analysis.
  - Ensure the relevant tables contain recent logs:
    - ◆ DeviceNetworkEvents
    - ◆ DeviceFileEvents
    - ◆ DeviceProcessEvents

### 3. Data Analysis

- **Goal:** Analyze data to test your hypothesis.
- **Activity:** Look for anomalies, patterns, or indicators of compromise (IOCs) using various tools and techniques.
  - Anything going on that you can notice in terms of excessive network connections to/from any hosts? Take note of the the query/logs/time

#### 4. Investigation

- **Goal:** Investigate any suspicious findings.
- **Activity:** Dig deeper into detected threats, determine their scope, and escalate if necessary. See if anything you find matches TTPs within the [MITRE ATT&CK Framework](#).
  - Search the DeviceFileEvents and DeviceProcessEvents tables around the same time based on your findings in the DeviceNetworkEvents tables to see if you can find more evidence for the cause of network slowdowns.
  - You can use ChatGPT to figure this out by pasting/uploading the logs: [Scenario 2 - TTPs](#):

| RemoteIP |  | LocalPort | RemotePort | InitiatingProcessCommandLine                                                   |
|----------|--|-----------|------------|--------------------------------------------------------------------------------|
| 10.0.0.7 |  | 60123     | 8443       | powershell.exe<br>-ExecutionPolicy Bypass<br>-File C:\programdata\portscan.ps1 |
| 10.0.0.7 |  | 60114     | 8080       | powershell.exe<br>-ExecutionPolicy Bypass<br>-File C:\programdata\portscan.ps1 |
| 10.0.0.7 |  | 60112     | 5900       | powershell.exe<br>-ExecutionPolicy Bypass<br>-File C:\programdata\portscan.ps1 |

Which TTPs in the MITRE ATT&CK framework do these logs appear to correlate to?

## ChatGPT said:

ChatGPT

The logs you've provided contain several relevant fields, including timestamps, action types (like "ConnectionFailed"), IP addresses (local and remote), ports, and the command line of the initiating process (which includes PowerShell commands).

Based on this information, here are some potential Tactics, Techniques, and Procedures (TTPs) from the MITRE ATT&CK framework that these logs may correlate with:

1. **T1059.001 - PowerShell (Command and Scripting Interpreter):** The log shows the use of PowerShell with an -ExecutionPolicy Bypass flag, which is often associated with bypassing system policies that limit script execution. This aligns with adversaries using PowerShell to execute commands on the system.
2. **T1071.001 - Web Protocols (Application Layer Protocol):** The logs indicate failed connections on ports typically associated with web traffic (e.g., 8443, 8080), which could suggest an attempt to communicate over web protocols. This could be indicative of adversaries using common web protocols to exfiltrate data or communicate with command and control servers.
3. **T1133 - External Remote Services:** Ports like 5900 (VNC), 3306 (MySQL), and 995 (POP3 over SSL) suggest potential attempts to interact with remote services. This tactic aligns with attempts to use or abuse remote services for lateral movement or data exfiltration.
4. **T1078 - Valid Accounts:** The recurring failed connection attempts could indicate the use of stolen or legitimate accounts, which correlates with attempts to leverage valid accounts for persistence or lateral movement.
5. **T1203 - Exploitation for Client Execution:** If the PowerShell commands involve downloading or running additional scripts or binaries, this could indicate exploitation of client-side software for code execution, especially in combination with command-and-control techniques.

I can help further correlate these logs to specific techniques if you have more context on the events leading up to these logs or more details from the environment where they occurred.

## 5. Response

- **Goal:** Mitigate any confirmed threats.

- **Activity:** Work with security teams to contain, remove, and recover from the threat.
  - Can anything be done?

## 6. Documentation

- **Goal:** Record your findings and learn from them.
- **Activity:** Document what you found and use it to improve future hunts and defenses.
  - Document what you did

## 7. Improvement

- **Goal:** Improve your security posture or refine your methods for the next hunt.
- **Activity:** Adjust strategies and tools based on what worked or didn't.
  - Anything we could have done to prevent the thing we hunted for? Any way we could have improved our hunting process?

## Notes / Findings:

**// Count up failed connections, take note of any IPs with excessive connections**

**DeviceNetworkEvents**

```
| where ActionType == "ConnectionFailed"
| summarize FailedConnectionsAttempts = count() by DeviceName, ActionType, LocalIP, RemoteIP
| order by FailedConnectionsAttempts desc
```

**// Observe total failed connections for a specific IP Address against other IPs**

**let IPInQuestion = "10.0.0.155";**

**DeviceNetworkEvents**

```
| where ActionType == "ConnectionFailed"
| where LocalIP == IPInQuestion
| summarize FailedConnectionsAttempts = count() by DeviceName, ActionType, LocalIP
| order by FailedConnectionsAttempts desc
```

**// Observe all failed connections for the IP in question. Notice anything?**

**let IPInQuestion = "10.0.0.155";**

**DeviceNetworkEvents**

```
| where ActionType == "ConnectionFailed"
| where LocalIP == IPInQuestion
| order by Timestamp desc
```

```
// Observe DeviceProcessEvents for the past 10 minutes of the unusual activity found
let VMName = "windows-target-";
let specificTime = datetime(2024-10-18T04:09:37.5180794Z);
DeviceProcessEvents
| where Timestamp between ((specificTime - 10m) .. (specificTime + 10m))
| where DeviceName == VMName
| order by Timestamp desc
| project Timestamp, FileName, InitiatingProcessCommandLine
```

**Timeline Summary and Findings:**

**Windows-target-1 was found failing several connection requests against itself and another host on the same network:**

```
DeviceNetworkEvents
| where ActionType == "ConnectionFailed"
| summarize ConnectionsCount = count() by DeviceName, ActionType, LocalIP, RemoteIP
| order by ConnectionsCount
<Query Results = 4 ConnectionFailed (ConnectionCount Results = 114, 26, 7, 7)
```

Filters: Add filter

| <input type="checkbox"/> | DeviceName                                                                                             | ActionType       | LocalIP                                                                                       | RemoteIP                                                                                        | ConnectionCount |
|--------------------------|--------------------------------------------------------------------------------------------------------|------------------|-----------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------|
| <input type="checkbox"/> | >  windows-target-1 | ConnectionFailed |  10.0.0.5  |  10.0.0.5  | 114             |
| <input type="checkbox"/> | >  windows-target-1 | ConnectionFailed |  10.0.0.5  |  10.0.0.4  | 26              |
| <input type="checkbox"/> | >  windows-target-1 | ConnectionFailed |  1         |  1         | 7               |
| <input type="checkbox"/> | >  windows-target-1 | ConnectionFailed |  127.0.0.1 |  127.0.0.1 | 7               |

After observing failed connection requests from a suspected host (10.0.0.5) in chronological order, I noticed a port scan was taking place due to the sequential order of the ports. There were several port scans being conducted:

```
// Observe all failed connections for the IP in question. Notice anything?
let IPInQuestion = "10.0.0.155";
DeviceNetworkEvents
| where ActionType == "ConnectionFailed"
```

| where LocalIP == IPInQuestion  
| order by Timestamp desc

---

I pivoted to the DeviceProcessEvents table to see if we could see anything that was suspicious around the time the port scan started. We noticed a Powershell script named portscan.ps1 launch at 2024-10-18T04:09:22.3022277Z

// Observe DeviceProcessEvents for the past 10 minutes of the unusual activity found

let VMName = "windows-target-";  
let specificTime = datetime(2024-10-18T04:09:37.5180794Z);

### **DeviceProcessEvents**

| where Timestamp between ((specificTime - 10m) .. (specificTime + 10m))  
| where DeviceName == VMName  
| order by Timestamp desc  
| project Timestamp, FileName, InitiatingProcessCommandLine

---

I logged into the suspect computer and observed the power shell script that was used to conduct the port scan:



```
1 # Define the log file path
2 $logfile = "C:\ProgramData\entropygorilla.log"
3 $scriptName = "portscan.ps1"
4
5 # Function to log messages
6 function Log-Message {
7     param (
8         [string]$message,
9         [string]$level = "INFO"
10    )
11    $timestamp = Get-Date -Format "yyyy-MM-dd HH:mm:ss"
12    $logEntry = "Timestamp [$level] [$scriptName] $message"
13    Add-Content -Path $logfile -Value $logEntry
14 }
15
16 # Define the range of IP addresses to scan
17 $startIP = 4
18 $endIP = 10
19 $baseIP = "10.0.0."
20
21 # Expanded list of common ports (well-known port numbers 0-1023 + some higher)
22 $commonPorts = @(21, 22, 23, 25, 53, 69, 80, 110, 123, 135, 137, 158, 139, 143, 162, 136, 443, 445, 488, 587, 993, 995, 3306, 3389, 5900, 8080, 8443)
```

I observed the port scan script was launched by the SYSTEM account, this is not expected behavior and is not something that was setup by the admins, so I isolated the device and ran malware scan.

---

### **Response and Actions:**

The malware scan produced no results, so out of caution, we kept the device isolated and put in a ticket to have it reimaged/rebuilt.

MITRE ATT&CK Framework Related TTPs:

- **Tactic:** Reconnaissance (TA0043)
  - **Technique:** Network Service Scanning (T1046)
  
- **Tactic:** Execution (TA0002)
  - **Technique:** Command and Scripting Interpreter: PowerShell (T1059.001)
  
- **Tactic:** Privilege Escalation (TA0004)
  - **Technique:** Valid Accounts: Local Accounts (T1078.003)
  
- **Tactic:** Defense Evasion (TA0005)
  - **Technique:** Obfuscated Files or Information (T1027)
  
- **Tactic:** Discovery (TA0007)
  - **Technique:** System Network Connections Discovery (T1049)
  
- **Tactic:** Lateral Movement (TA0008) (Potential Future Phase)
  - **Technique:** Remote Services (T1021)